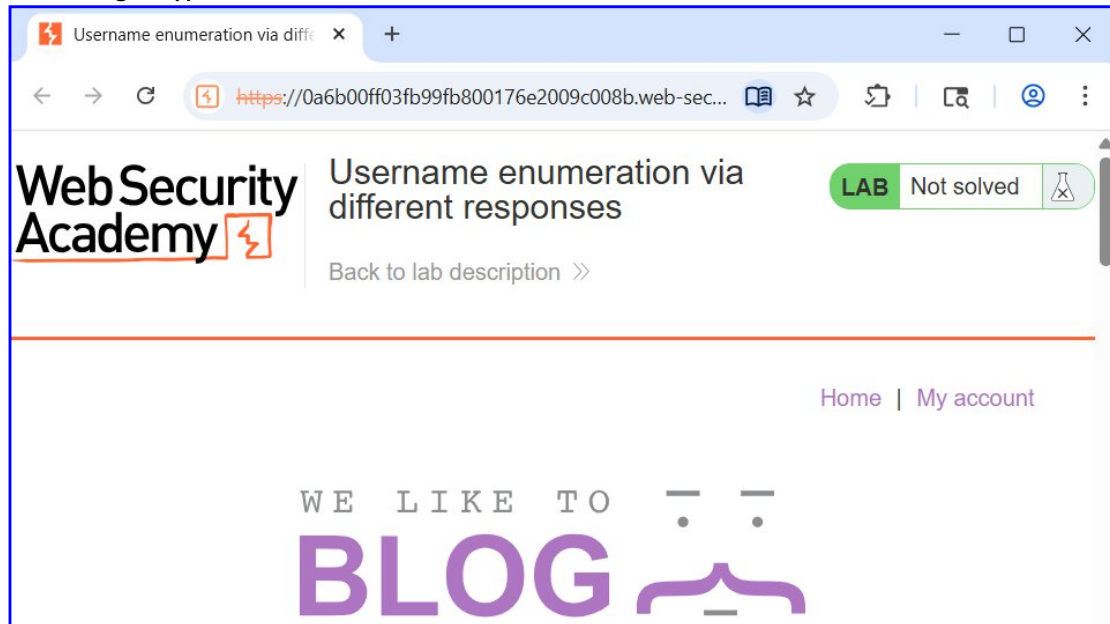


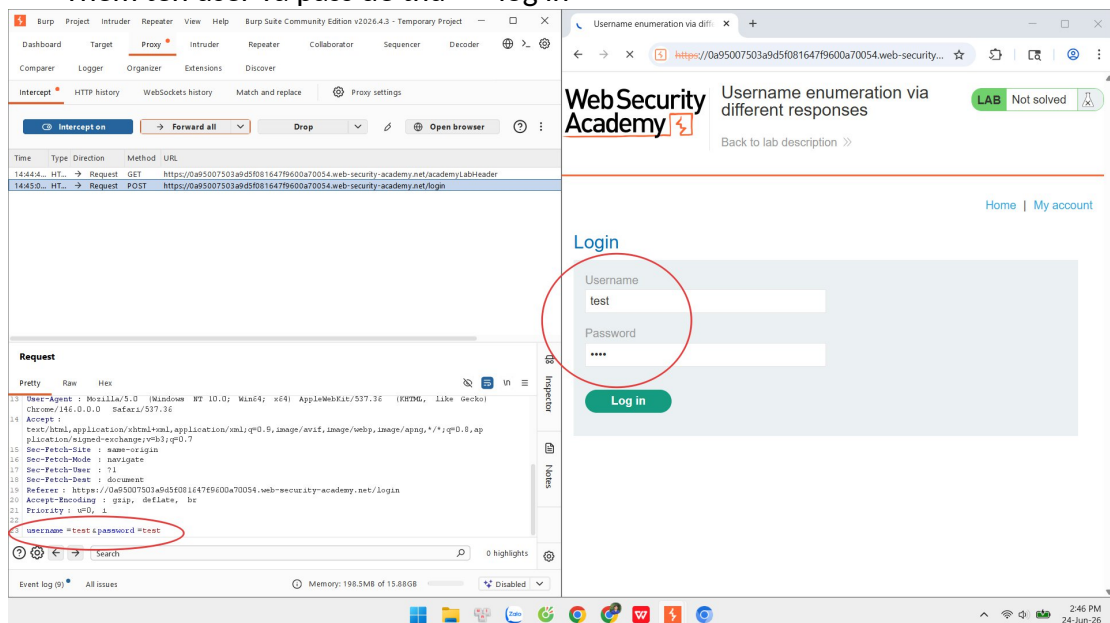
Tranh A Nguyen  
June 2026

## Username enumeration via different responses

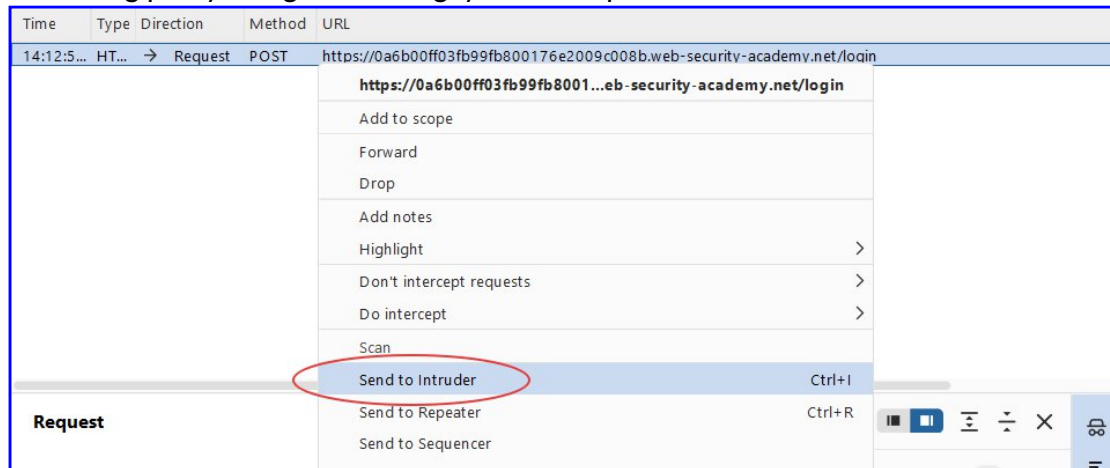
- Trong burp vào proxy bật interpret
- đăng nhập các thử



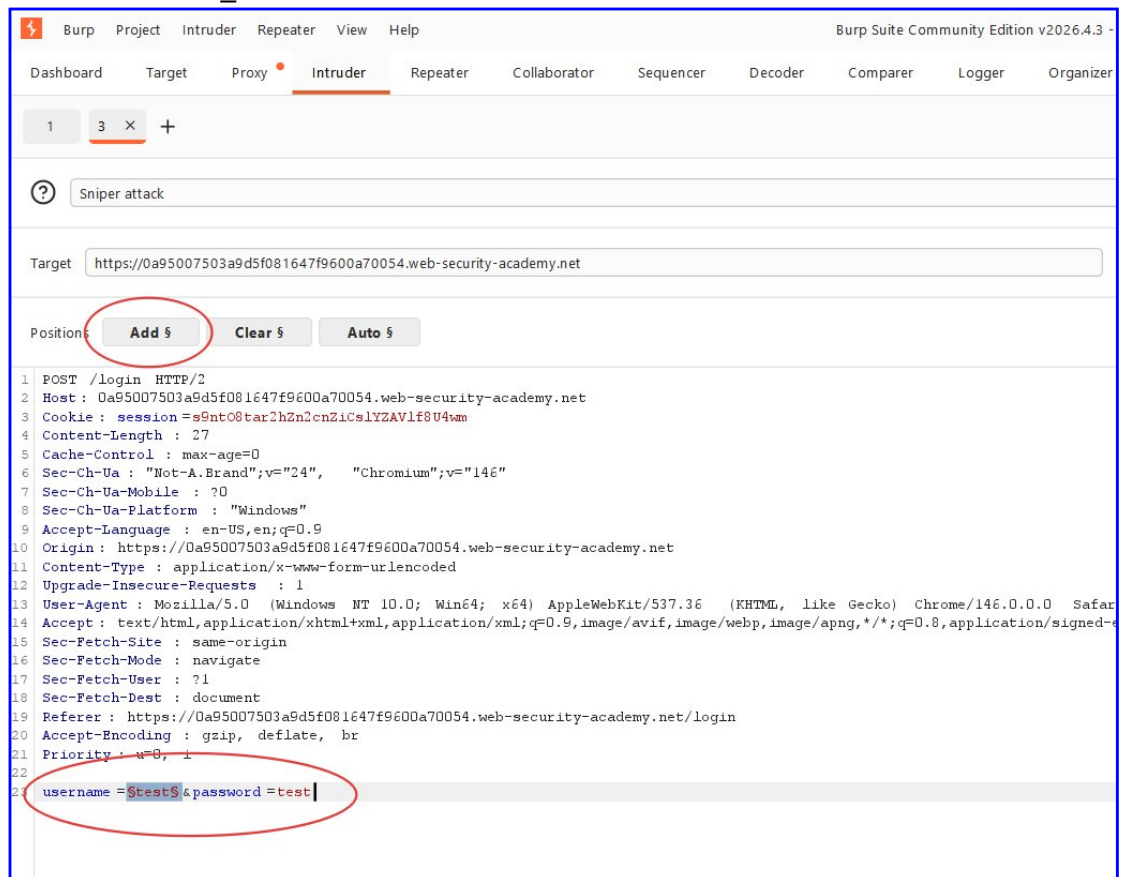
- Chọn “My account”
- Thêm tên user và pass để thử --> log in



- Trong proxy trong forward ngay mà sent qua intruder để brute force



- Tab Intruder
- Trong positions
- Bôi đen test\_user --> add



- Copy dữ liệu tên user từ portswigger paste vào payloads của intruder

- Tấn công !!!
- Bật start attack
- Sau khi finish chỉ có agent là có length khác (3354)

|    |            |     |     |      |
|----|------------|-----|-----|------|
| 40 | affiliate  | 200 | 209 | 3352 |
| 41 | affiliates | 200 | 252 | 3352 |
| 42 | afiliados  | 200 | 263 | 3352 |
| 43 | ag         | 200 | 205 | 3352 |
| 44 | agenda     | 200 | 245 | 3352 |
| 45 | agent      | 200 | 247 | 3354 |
| 46 | ai         | 200 | 263 | 3352 |
| 47 | aix        | 200 | 206 | 3352 |
| 48 | ajax       | 200 | 293 | 3352 |
| 49 | ak         | 200 | 207 | 3352 |

- đổi lại tên user và chọn mật khẩu

```
23 username = agent & password = $test$
```

- tiếp tục brute force mật khẩu

- Pass = 555555
- Status code cho biết 200 là ok còn 302 là đang chuyển sang URL khác, khả năng làm đường link của người dùng này
- Hoặc nhìn length cũng thấy nó khác với những cái xung quang

|    |          |     |     |      |
|----|----------|-----|-----|------|
| 61 | jessica  | 200 | 273 | 3354 |
| 62 | pepper   | 200 | 235 | 3354 |
| 63 | 1111     | 200 | 246 | 3354 |
| 64 | zxcvbn   | 200 | 234 | 3354 |
| 65 | 555555   | 302 | 270 | 187  |
| 66 | 11111111 | 200 | 203 | 3441 |
| 67 | 131313   | 200 | 253 | 3441 |
| 68 | freedom  | 200 | 252 | 3441 |
| 69 | 777777   | 200 | 216 | 3441 |

- Thử lại với user và pass đã brute force được

The screenshot shows a web browser window displaying the 'WebSecurity Academy' login page. The page title is 'Username enumeration via different responses'. The login form has fields for 'Username' (containing 'agent') and 'Password' (containing '\*\*\*\*\*'), and a 'Log in' button. An error message 'Invalid username' is displayed above the username field. To the left, the Burp Suite interface is visible, showing the HTTP history of the browser. A POST request to 'https://0a95007503a9d5f081647f9600a70054.web-security-academy.net/login' is highlighted, with a payload of 'username=agent&password=555555' circled in red.

## Vào thành công và đổi email

The screenshot shows a web browser window displaying the 'WebSecurity Academy' 'My Account' page. The page title is 'Username enumeration via different responses'. The account information shows 'Your username is: agent' and 'Your email is: agent@normal-user.net'. Below this, there is a form to change the email, with the current email 'agent@normal-user.net' and a new email 'tranhlearnsecurity@gmail.com' entered. An 'Update email' button is at the bottom. To the left, the Burp Suite interface is visible, showing the HTTP history. A GET request to 'https://0a95007503a9d5f081647f9600a70054.web-security-academy.net/my-account/change-email' is highlighted.

## LAB DONE!

Web Security Academy

### Username enumeration via different responses

LAB Solved

Back to lab description >>

Congratulations, you solved the lab! Share your skills! Continue learning >>

Home | My account | Log out

#### My Account

Your username is: agent

Your email is: tranhlearnsecurity@gmail.com

## Lưu ý:

- Khi đặt tên biến và \$ sẽ bị lỗi khi tấn công nên cần để ý

Burp Suite Community Edition v2026.4.3 - T

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer

1 2 x +

Sniper attack

Target: `https://0a6b00ff03fb99fb800176e2009c008b.web-security-academy.net`

Positions: Add \$ Clear \$ Auto \$

```
1 POST /login HTTP/2
2 Host: 0a6b00ff03fb99fb800176e2009c008b.web-security-academy.net
3 Cookie: session=QdynNk5c7yMYEPdWb9qn2pb8rAO7xqyD
4 Content-Length: 37
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin: https://0a6b00ff03fb99fb800176e2009c008b.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.0
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0a6b00ff03fb99fb800176e2009c008b.web-security-academy.net/login
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 username=$test_user&password=test_pass
```

## Giải thích thêm:

**Tại sao lại Click chuột phải → Send to Intruder → bôi đen test ở username=\$test\$ ???**

- Intruder là công cụ tự động thay thế một giá trị trong request bằng từng item trong danh sách. Dấu \$...\$ chính là ô trống mà Intruder sẽ lần lượt điền vào.
- Nếu bạn đặt marker sai vị trí (ví dụ bôi cả username=test) thì payload sẽ thay thế luôn cả tên field → request bị lỗi format → attack thất bại.

**Tại sao lại Payloads → Simple list → Paste danh sách ~100 username → Start attack ????**

- Server không thông báo trực tiếp "username này tồn tại hay không", nhưng nó vô tình lộ thông tin qua thông báo lỗi:
- Username không tồn tại --> Invalid username
- Username tồn tại, password sai --> Incorrect password

**Tại sao Nhìn cột Length → agent có Length = 3354, tất cả còn lại = 3352 ???**

- Khi nội dung response thay đổi (từ Invalid username → Incorrect password), độ dài trang HTML cũng thay đổi theo. Chênh lệch 2 byte = đúng bằng độ dài chữ khác nhau giữa hai thông báo.
- Đây là cách phát hiện sự khác biệt mà không cần đọc từng response

**Tại sao lại sửa username=agent, đặt marker vào password=\$test\$ → load password list → Start attack ???**

- Sau khi có username đúng, ta biết chắc tài khoản tồn tại. Bây giờ chỉ cần tìm password. Phương pháp tương tự — thử từng password trong danh sách phổ biến.
- Lần này dấu hiệu nhận biết là Status Code 302 thay vì 200:
- 200 OK = đăng nhập thất bại, server trả về trang lỗi
- 302 Found = đăng nhập thành công, server redirect sang trang chủ

## Bài học rút ra:

**Thông báo lỗi quá chi tiết = lỗ hổng bảo mật**

Server đang vô tình giúp cho attacker biết:

- "Invalid username" → username này không tồn tại
- "Incorrect password" → username này có tồn tại, chỉ sai password

Chỉ cần quan sát sự khác biệt đó, attacker có thể dùng Intruder để tìm ra tài khoản hợp lệ rồi brute force tiếp password — mà không cần biết gì trước.

Cách fix chỉ một dòng:

sai "Invalid username"

sai "Incorrect password"

đúng "Invalid username or password" ← gộp lại, không tiết lộ gì cả

À nếu muốn xem "Invalid username", "Incorrect password", "Invalid username or password" chi tiết hơn thì xem trong response NHƯNG nhìn sort cái length là nhanh nhất